



MASTG

0014: Testing the Configuration of Cryptographic Standard Algorithms

- MASTG-TEST-0015: Testing the Purposes of Keys
- MASTG-TEST-0016: Testing Random Number Generation
- MASTG-TEST-0204: Insecure Random API Usage
- MASTG-TEST-0205: Non-random Sources Usage
- MASTG-TEST-0208: Insufficient Key Sizes
- MASTG-TEST-0212: Use of Hardcoded Cryptographic Keys in Code

L1

L2

ANDROID

MASWE-0027

TEST



MASTG-TEST-0204: Insecure Random API Usage

Overview

Android apps sometimes use an insecure [pseudorandom number generator \(PRNG\)](#), such as `java.util.Random` ↗, which is a linear congruential generator and produces a predictable sequence for any given seed value. As a result, `java.util.Random` and `Math.random()` (the latter ↗ simply calls `nextDouble()` on a static `java.util.Random` instance) generate reproducible sequences across all Java implementations whenever the same seed is used. This predictability makes them unsuitable for cryptographic or other security-sensitive contexts.

In general, if a PRNG is not explicitly documented as being cryptographically secure, it should not be used where randomness must be unpredictable. Refer to the [Android Documentation](#) ↗ and the "[random number generation](#)" guide for further details.

Steps

- Run a static analysis ([↗ Static Analysis on Android](#)) tool on the app and look for insecure random APIs, or you can use [↗ Method Tracing](#) to detect the use of such APIs.
- For each of the identified API uses, check if they are used in a security relevant context. You can decompile the app ([↗ Decompiling Java Code](#)) and inspect the code ([↗ Reviewing Decompiled Java Code](#)) to confirm.

Observation

The output should contain a list of locations where insecure random APIs are used.

Evaluation

The test case fails if you can find random numbers generated using those APIs that are used in security-relevant contexts, such as generating passwords or authentication tokens.

Best Practices

ANDROID MASTG-BEST-0001: Use Secure Random Number Generator APIs

Demos

ANDROID MASTG-DEMO-0007: Common Uses of Insecure Random APIs

